Inteligência de Ameaças e Detecção com Sigma

1. Indicadores de Comprometimento (IOCs)

IOCs são artefatos ou vestígios deixados por um adversário em uma rede. Eles funcionam como "impressões digitais" que ajudam a identificar intrusões anteriores ou tentativas de reintrusão.

1.1. Expansão de Escopo

Durante uma investigação, um IOC frequentemente leva a outro. No caso analisado:

- **IOC Direto:** bad3xe69connection[.]io
- **IOCs Associados:** Através da análise de infraestrutura, identificou-se a conexão com kind4bad.com e nic3connection.io.

2. Padronização com Sigma

Para evitar a dependência de um único fornecedor (SIEM/EDR), utilizamos o **Sigma**. O Sigma é uma linguagem de assinatura genérica e de código aberto que permite descrever eventos de log em um formato estruturado (YAML).

2.1. Anatomia de uma Regra Sigma

Uma regra Sigma converte a inteligência bruta em um formato legível por máquina e por humanos:

- **Logsource:** Define onde a regra deve procurar (ex: logs de proxy, rede ou processos).
- **Detection:** Define os critérios de seleção (o que é malicioso).
- **Condition:** Define a lógica da detecção.

3. Implementação Prática: Detecção de Domínios Suspeitos

Abaixo, a regra desenvolvida para detectar o download de executáveis a partir dos domínios identificados na planilha de IOCs:

```
title: Executable Download from Suspicious Domains
status: test
description: Detecta o download de executáveis originados de hosts listados na planilha de IOCs.
author: Mokmokmok
logsource:
  category: proxy
```

```
detection:
  selection:
    c-uri-extension:
      - 'exe'
    r-dns:
      - 'bad3xe69connection.io'
      - 'kind4bad.com'
      - 'nic3connection.io'
  condition: selection
level: medium
```

4. Defesa em Camadas

A eficácia da segurança não depende de uma única regra "mágica", mas da **Defesa em Profundidade**. Enquanto um atacante precisa contornar todas as defesas para ter sucesso, o defensor precisa apenas que o atacante falhe em **uma única camada** de detecção para expor sua presença.

Resposta Rápida a Zero-Days com Sigma e Uncoder

1. Visão Geral

A detecção de vulnerabilidades **Zero-Day** (como Follina e Log4j) exige velocidade. A comunidade de segurança compartilha indicadores e regras **Sigma** que podem ser convertidos para ferramentas específicas (SIEM) para resposta imediata.

2. Ferramentas de Tradução: Uncoder.io

O **Uncoder** é uma plataforma que atua como um tradutor de "idoma de segurança", convertendo regras Sigma (genéricas) em consultas específicas para Elastic Stack, Splunk, Microsoft Sentinel e outros.

---

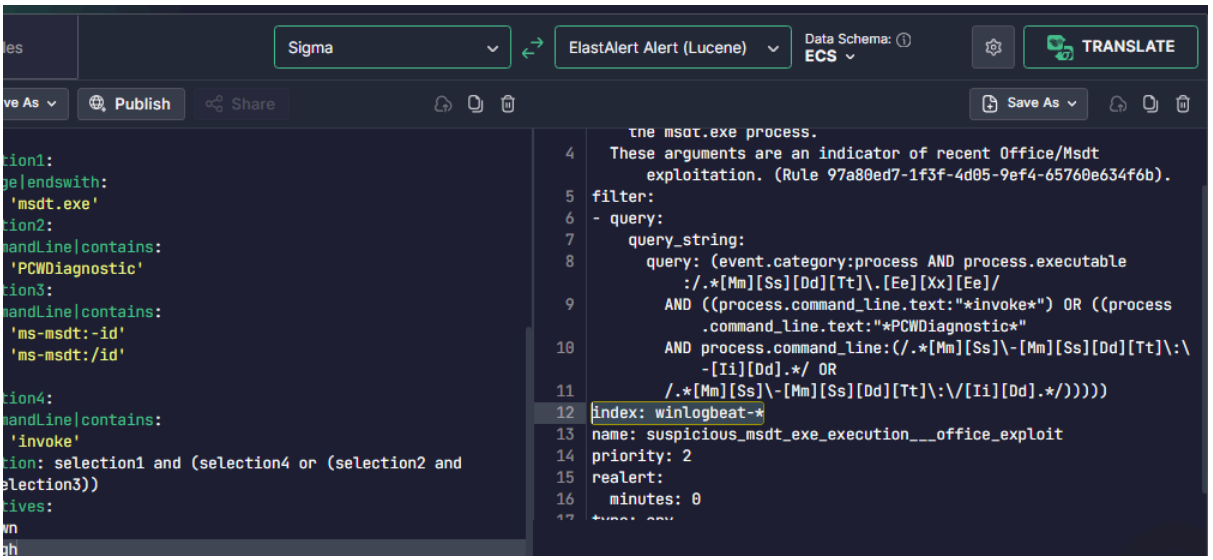
3. Estudo de Caso 1: Vulnerabilidade Follina (MSDT)

A vulnerabilidade Follina-MSDT explora o utilitário de diagnóstico da Microsoft através do Office.

3.1. Tradução para ElastAlert

Ao converter a regra Sigma do Follina para o formato **ElastAlert**, obtemos a estrutura necessária para alertas automáticos no Elastic.

- **Índice Alvo:** `winlogbeat-*`
- **Subclasse Alerter:** `debug` (conforme padrão de saída do Uncoder para testes).



3.2. Tradução para Elasticsearch Query (Lucene)

Para buscas manuais no **Kibana (Discover)**, a tradução para Lucene é a mais indicada.

- **Consulta Gerada:** `(event.category:process AND process.executable:/.*[Mm][Ss][Dd][Tt]\.[Ee][Xx][Ee]/AND ((process.command_line.text:"*invoke*") OR ((process.command_line.text:"*PCWDiagnostic*" AND process.command_line:(/.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\-[Ii][Dd].*/ OR/.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\/[Ii][Dd].*/)))))`

Elastic Stack Query (Lu... | Data Schema: ECS | TRANSLATE | Save As

```
(event.category:process AND process.executable:/.*[Mm][Ss][Dd][Tt]\
    .[Ee][Xx][Ee]/ AND ((process.command_line.text:"*invoke*") OR
    ((process.command_line.text:"*PCWDiagnostic*" AND process
    .command_line:(/.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\-[Ii][Dd].*/ OR
    /.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\/[Ii][Dd].*/))))
```

ElastAlert Alert (Lucene) | Data Schema: ECS | TRANSLATE | Save As

```
alert:
- debug
description: This rule will monitor suspicious arguments passed to
    the msdt.exe process.
  These arguments are an indicator of recent Office/Msdt
      exploitation. (Rule 97a80ed7-1f3f-4d05-9ef4-65760e634f6b).
filter:
- query:
    query_string:
      query: (event.category:process AND process.executable
          :/.*[Mm][Ss][Dd][Tt]\.[Ee][Xx][Ee]/
        AND ((process.command_line.text:"*invoke*") OR ((process
            .command_line.text:"*PCWDiagnostic*"
        AND process.command_line:(/.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\
            -[Ii][Dd].*/ OR
        /.*[Mm][Ss]\-[Mm][Ss][Dd][Tt]\:\/[Ii][Dd].*/)))))
index: winlogbeat-*
name: suspicious_msdt_exe_execution___office_exploit
```

---

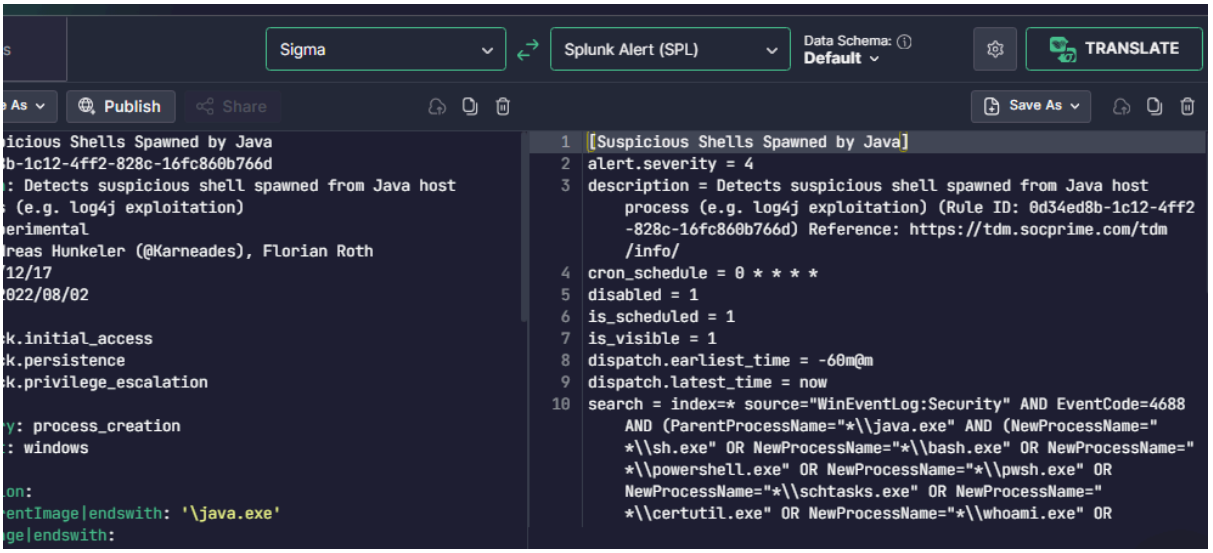
4. Estudo de Caso 2: Vulnerabilidade Log4j

O Log4j permitia execução remota de código (RCE) que frequentemente resultava na criação de *shells* suspeitos a partir de processos Java.

4.1. Conversão para Alerta do Splunk (SPL)

Ao traduzir a regra para o Splunk, o Uncoder gera as configurações de alerta e a query SPL.

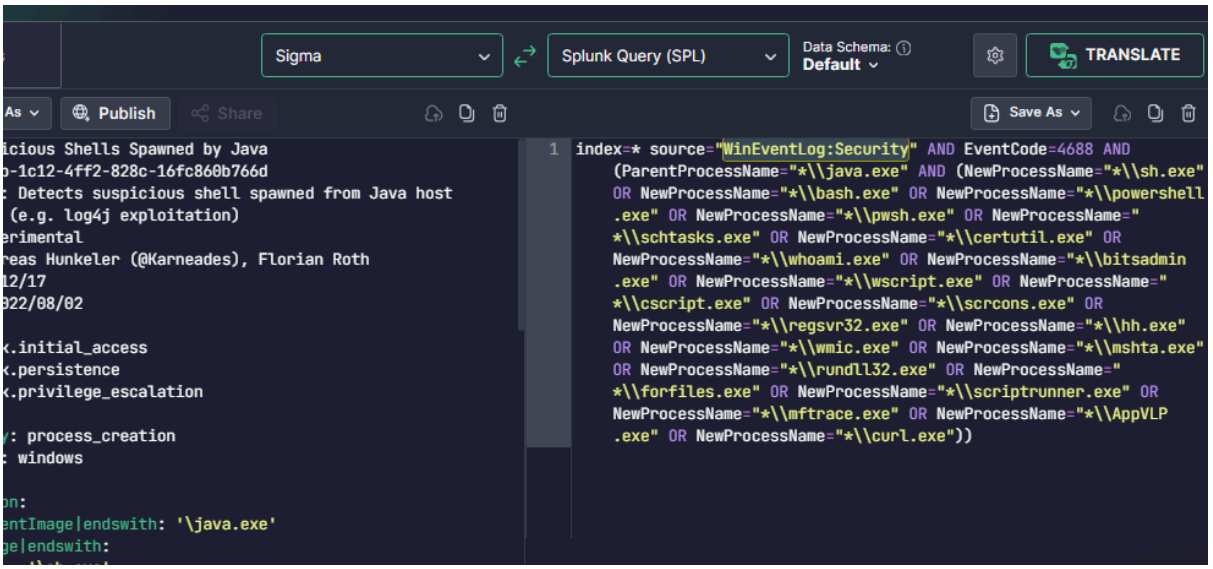
- **Gravidade (Severity):** 3
- **Earliest Time:** `-60m@m`



4.2. Consulta Direta no Splunk (SPL)

Diferente do alerta, a query SPL foca na busca direta nos logs.

- **Source:** WinEventLog:Security (Fonte de logs do Windows no Splunk).



Estratégias de Deception e Auditoria de Acesso a Objetos

1. Visão Geral: O Valor dos "Dados Sensíveis" na Detecção

A detecção baseada em ativos específicos aproveita a assimetria de informação. Ao definir controles rigorosos sobre arquivos ultrassensíveis (os "Mapas do Tesouro"), qualquer interação não autorizada torna-se um sinal de alta fidelidade para a equipe de segurança. Esta abordagem reduz o ruído dos alertas comuns e foca no que é vital para a organização.

2. Mecanismos de Detecção Automática (Honeypots e Canários)

Para lidar com os "desconhecidos desconhecidos" (ameaças para as quais não há assinaturas), utilizamos ferramentas de engodo:

- **Honeypots:** Sistemas ou ativos sem finalidade comercial legítima. Como não há tráfego esperado neles, 100% da atividade capturada é considerada suspeita.
- **Arquivos/Pastas Ocultos:** Atuam como armadilhas para malwares de propagação lateral (como Worms e Ransomwares). Usuários comuns não interagem com arquivos ocultos, tornando-os sensores ideais para detectar intrusões automatizadas.

3. Implementação de Auditoria de Acesso a Objetos (Windows)

A implementação prática de um sistema de "armadilha com fio" (wiretrap) em ambiente Windows baseia-se na configuração de políticas de auditoria granulares.

3.1. Política de Segurança Local

A base da detecção reside na ativação da **Política de Auditoria de Acesso a Objetos**. Ao configurar o monitoramento tanto para "Sucesso" quanto para "Falha", garantimos a visibilidade sobre:

1. **Tentativas bem-sucedidas:** Revelam vazamento de dados ou acesso indevido.
2. **Tentativas fracassadas:** Revelam exploração de permissões ou ataques de força bruta.

3.2. Configurações de SACL (System Access Control List)

Para que um arquivo específico (ex: "Documento Secreto") atue como um sensor, configuramos uma Entrada de Auditoria em suas propriedades avançadas de segurança:

- **Entidade Principal:** Definida como "Todos", garantindo que nenhum usuário (seja admin ou convidado) escape do log.
- **Ações Auditadas:** Monitoramento de leitura, modificação e exclusão.

4. Análise e Resposta: O Event ID 4663

O resultado técnico desta configuração é a geração de logs no Event Viewer de Segurança sob o **ID de Evento 4663** (*An attempt was made to access an object*).

Este ID é uma peça fundamental para o SIEM, pois fornece metadados críticos:

- **Quem** acessou (Conta de usuário).
- **O quê** foi acessado (Caminho do arquivo).
- **Como** foi acessado (Leitura, Escrita, Exclusão).
- **Qual** processo foi utilizado (ex: notepad.exe, cmd.exe).